

# **AnkaCORE26**

## **Siber Güvenlik**

### **3. Hafta**

İlayda Aytaş

24.02.2026

## Bölüm A: Teori ve Mimari (Research & Logic)

1.1 -Dosyalara ulaşmak daha kolay oluyor. Hepsi sonuçta sadece terminalden yazılan kod.

1.2 - 777 demek herkezin yazıp okuyup çalıştırabilir demek ve bu tehlikeli.

1.3 - Bie dosyayı root yetkisiyle çalıştırabilmeye yarar SUID biti , yani o komutu root yetkisi ile çalıştırabiliyor oluyoruz root olmasak bile.

find / -perm -4000

4000 suid bitini temsil eder

Bilgisayarda root yetkisiyle çalışabilen programları arar.

Potansiyel privilege escalation yüzeyine bakarlar yanlış yapılanmış dosya var mı diye.

1.4 -

Belleğe tamamını yüklemes (stream processing)

O(1) memory yaklaşımı

Büyük veri üzerinde hızlı analiz

Otomasyona uygun

Incident response süresini kısaltır

2.1- Ring 0 işletim sistemi çekirdeği ve donanımların aslında kodlanması onların yönetilmesi burada yapılır.

Ring 3 de de genel kullanıcıların yaptığı işlemler var donanım veya işletim sistemini etkilemezler . Böylece yanlışlıkla tüm sistemi çekirdeği etkileyip mavi ekran almayız. çökerse sadece kendisi gider

2.2 -

Registry = Windows'un **kalıcı ayar veritabanı**

- Diskte saklanır
- Bilgisayar kapanınca silinmez
- Windows her açıldığında buradan ayarları okur
- Windows açılırken Registry okunur

- Okunan bilgiler RAM'e yüklenir
- Programlar çalışırken RAM kullanılır

HKLM bilgisayardaki tüm kullanıcıları etkiler

HKCU 1 kullanıcıyı etkiler yanı onun tercihleridir ayarlarıdır

Bilgisayar başlayınca otomatik çalışan uygulamalar registry içindedir

...\\CurrentVersion\\Run

Bu klasörün mantığı şudur:

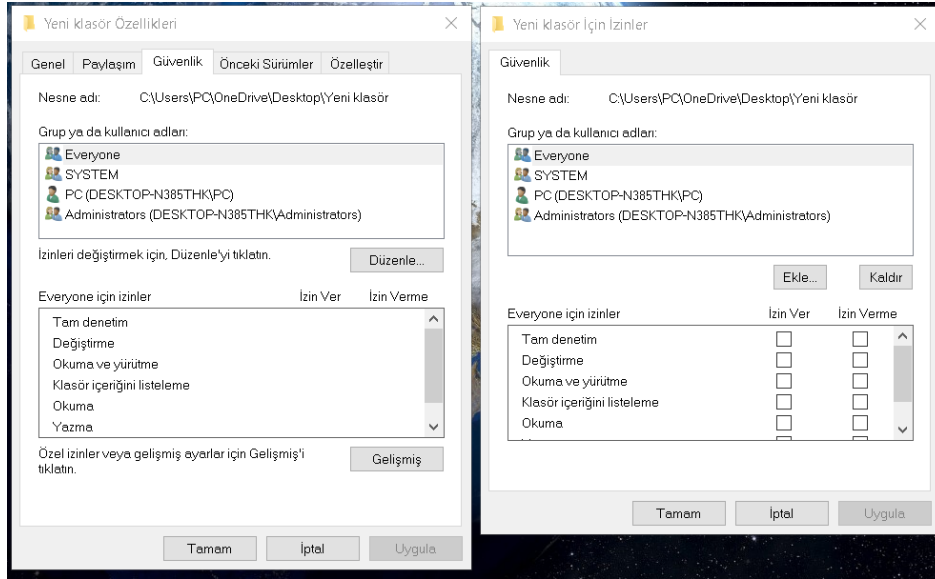
“Bilgisayar açılınca şunları çalıştır.”

Trojen de eğer kendisini eklerse o zaman bilgisayarı kaatıp açınca tekrar çalışır ve **Persistence (Kalıcılık) sağlar .**

2.3-

ACL şunu söyler:

- Kim?
- Ne yapabilir?
- Ne yapamaz?
  
- Hassas dosyalar korunur
- Servis hesapları sınırlandırılır
- İç tehditler azaltılır
- Yetki ayrımı (least privilege) sağlanır



## Bölüm B: Saha Eğitimi (TryHackMe - Lab)

### Görev 1: Linux Cephisi - Terminalle Tanışma

Grep komutu

```
tryhackme@linux1:~$ grep "THM" access.log
13.127.130.212 - - [04/May/2021:08:35:26 +0000] "GET THM{ACCESS} lang=en HTTP/1.1" 404 360 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/77.0.3865.120 Safari/537.36"
```

Sudo -l

```
root@ip-10-80-75-135:~# sudo -l
sudo: unable to resolve host ip-10-80-75-135: Name or service not known
Matching Defaults entries for root on ip-10-80-75-135:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User root may run the following commands on ip-10-80-75-135:
    (ALL : ALL) ALL
root@ip-10-80-75-135:~#
```

Ps aux

```

root@ip-10-80-75-135:~# ps
  PID TTY          TIME CMD
 3247 pts/1    00:00:00 bash
 5899 pts/1    00:00:00 su
 5907 pts/1    00:00:00 bash
 6061 pts/1    00:00:00 su
 6062 pts/1    00:00:00 bash
 6995 pts/1    00:00:00 ps
root@ip-10-80-75-135:~# ps aux
USER            PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root              1  0.2  0.3 105112 14112 ?        Ss   14:43   0:03 /sbin/init
root              2  0.0  0.0      0      0 ?        S    14:43   0:00 [kthreadd]
root              3  0.0  0.0      0      0 ?        I<   14:43   0:00 [rcu_gp]
root              4  0.0  0.0      0      0 ?        I<   14:43   0:00 [rcu_par_gp]
root              5  0.0  0.0      0      0 ?        I<   14:43   0:00 [slub_flushwq]
root              6  0.0  0.0      0      0 ?        I<   14:43   0:00 [netns]
root              8  0.0  0.0      0      0 ?        I<   14:43   0:00 [kworker/0:0H-events
[highpri]
root             10  0.0  0.0      0      0 ?        I<   14:43   0:00 [mm_percpu_wq]
root             11  0.0  0.0      0      0 ?        S    14:43   0:00 [rcu_tasks_rude_]
root             12  0.0  0.0      0      0 ?        S    14:43   0:00 [rcu_tasks_trace]
root             13  0.0  0.0      0      0 ?        S    14:43   0:00 [ksoftirqd/0]
root             14  0.0  0.0      0      0 ?        I    14:43   0:01 [rcu_sched]
root             15  0.0  0.0      0      0 ?        S    14:43   0:00 [migration/0]
root             16  0.0  0.0      0      0 ?        S    14:43   0:00 [idle_inject/0]
root             18  0.0  0.0      0      0 ?        S    14:43   0:00 [cpuhp/0]
root             19  0.0  0.0      0      0 ?        S    14:43   0:00 [cpuhp/1]
root             20  0.0  0.0      0      0 ?        S    14:43   0:00 [idle_inject/1]
root             21  0.0  0.0      0      0 ?        S    14:43   0:00 [migration/1]
root             22  0.0  0.0      0      0 ?        S    14:43   0:00 [ksoftirqd/1]

```

## Görev 2: Windows Anatomisi - "Normal"i Tanımak

|          |   |                                          |
|----------|---|------------------------------------------|
| Görev 1  | ✓ | Giriş                                    |
| Görev 2  | ✓ | Görev Yöneticisi                         |
| Görev 3  | ✓ | Sistem                                   |
| Görev 4  | ✓ | Sistem > smss.exe                        |
| Görev 5  | ✓ | csrss.exe                                |
| Görev 6  | ✓ | wininit.exe                              |
| Görev 7  | ✓ | wininit.exe > hizmetler.exe              |
| Görev 8  | ✓ | wininit.exe > services.exe > svchost.exe |
| Görev 9  | ✓ | lsass.exe                                |
| Görev 10 | ✓ | winlogon.exe                             |
| Görev 11 | ✓ | explorer.exe                             |
| Görev 12 | ✓ | Sonuç                                    |

**1. System (PID 4)** PID 4 sabit çünkü Windows her açılışta kernel'ı ilk o başlatır ve bu değer değişmesi mümkün değil. Aslında bu bir "süreç" değil, kernel'ın kendisi. Donanım, bellek, driver'lar hepsi onun üzerinden yönetilir.

**2. smss.exe** Windows'un "hazırlık aşaması" diyebilirim. Oturumları başlatır, sayfa dosyasını (pagefile) oluşturur, ortam değişkenlerini hazırlar ve ardından csrss ile winlogon'u doğurur. İşi bitince sessizce kenara çekilir.

**3. csrss.exe** Windows'un kullanıcı arayüzünün temel taşı — konsol pencereleri, thread yönetimi, process'lerin doğru kapanması gibi kritik işleri halleder. Kernel ile kullanıcı uygulamaları arasındaki köprü olduğu için onu öldürdüğünde sistemin ayakta duracağı zemin kalmıyor, BSOD kaçınılmaz oluyor.

**4. lsass.exe** Hacker'ların gözü bu süreçte çünkü tüm aktif kullanıcıların şifre hash'lerini bellekte tutar.

5. **svchost.exe** Windows servisleri tek tek ayrı process olarak çalışsaydı sistem felç olurdu. Bunun yerine birden fazla servis aynı svchost örneğini paylaşır.

## 🔪 BÖLÜM C: Operasyonel Görev (Boss Fight)

### 🐼 Cephe 1: OverTheWire - Bandit (Linux)

0- Ssh bağlantısında

ssh username@bandit.labs.overthewire.org(host) -p 2220 yaptık

```
bandit0@bandit:~$ ls
readme
bandit0@bandit:~$ cat readme
Congratulations on your first steps into the bandit game!!
Please make sure you have read the rules at https://overthewire.org/rules/
If you are following a course, workshop, walkthrough or other educational activity,
please inform the instructor about the rules as well and encourage them to
contribute to the OverTheWire community so we can keep these games free!

The password you are looking for is: ZjLjTmM6FvvyRnrb2rfNW0Z0Ta6ip5If
```

1- -nin bir file olduğunu belirtmek için ./ kullandık

```
bandit1@bandit:~$ cat ./-
263JGJPfgU6LtdEvqfWU1XP5yac29mFx
bandit1@bandit:~$
```

2- Linux'ta boşluk özel karakterdir. Terminal boşluğu “ayraç” olarak görür.

Boşlukların önüne \ koydum

file i option sandı - bundan dolayı.

```
bandit2@bandit:~$ cat ./--spaces\ in\ this\ filename--
MNk8KNH3Usiio41PRUEoDFPqfxLPISmx
bandit2@bandit:~$
```

3- -a ile gizli dosyaya eriştim.

```
bandit3@bandit:~$ ls
inhere
bandit3@bandit:~$ cat inhere
cat: inhere: Is a directory
bandit3@bandit:~$ cd inhere
bandit3@bandit:~/inhere$ ls
bandit3@bandit:~/inhere$ ls -a
.  ..  ... Hiding-From-You
bandit3@bandit:~/inhere$ cat Hiden-From-You
cat: Hiden-From-You: No such file or directory
bandit3@bandit:~/inhere$ cat ... Hiding-From-You
2WmrDFRmJIq3IPxneAaMGhap0pFhF3NJ
bandit3@bandit:~/inhere$
```

4- klasörde bir sürü dosya var ama sadece **bir tanesi metin dosyası**.

Tek tak baktım

```
bandit4@bandit:~$ ls
inhere
bandit4@bandit:~$ cd inhere
bandit4@bandit:~/inhere$ ls
-file00 -file02 -file04 -file06 -file08
-file01 -file03 -file05 -file07 -file09
bandit4@bandit:~/inhere$ cat ./-file00
*=
I== **V`n*5***e***G^7c0*bandit4@bandit:~/inhere$ cat ./-file01
***0**w*8***q***Y***d***ZCF***bandit4@bandit:~/inhere$ cat ./-file02
*** L****Q*.***`//***r
*P{bandit4@bandit:~/inhere$ cat ./-file03
***?***1'JV****,***2**
f***bandit4@bandit:~/inhere$ cat ./-file04
**us*****w**Z **I|**@*Sq-bandit4@bandit:~/inhere$ cat ./-file05
W*cF***[Q
*
**a~***\0*ed(**Wbandit4@bandit:~/inhere$ cat ./-file06
?z=J"***oyvbandit4@bandit:~/inhere$ cat ./-file07
4oQYVPkxZ00E005pTW81FB8j8lxXGUQw
```

5-

```
bandit5@bandit:~$ ls
inhere
bandit5@bandit:~$ cd inhere
bandit5@bandit:~/inhere$ ls
maybeh000 maybeh004 maybeh008 maybeh012 maybeh016
maybeh001 maybeh005 maybeh009 maybeh013 maybeh017
maybeh002 maybeh006 maybeh010 maybeh014 maybeh018
maybeh003 maybeh007 maybeh011 maybeh015 maybeh019
bandit5@bandit:~/inhere$ ls -a
.  ..  maybeh002 maybeh006 maybeh010 maybeh014 maybeh018
..  maybeh003 maybeh007 maybeh011 maybeh015 maybeh019
maybeh000 maybeh004 maybeh008 maybeh012 maybeh016
maybeh001 maybeh005 maybeh009 maybeh013 maybeh017
bandit5@bandit:~/inhere$ find -type f -size 1033c ! -executable
./maybeh007/.file2
bandit5@bandit:~/inhere$ cat ./maybeh007/.file2
HWasnPhtq9AVKe0dmk45nxy20cvUa6EG
```

6-

/ → tüm sistemi tara

- -type f → sadece dosyalar



- -user bandit7 → sahibi bandit7
- -group bandit6 → grubu bandit6
- -size 33c → 33 byte
- 2>/dev/null → permission hatalarını gizler

## 2>/dev/null ne demek?

### 1 2 ne?

Linux'ta 3 tane standart akış vardır:

- 0 → stdin (giriş)
- 1 → stdout (normal çıktı)
- 2 → stderr (hata çıktısı)

Yani **2 = hata mesajları** demek.

### 2 > ne?

> yönlendirme operatörüdür.

Bir çıktıyı başka bir yere gönderir.

### 3 /dev/null ne?

/dev/null özel bir dosyadır.

İçine atılan her şeyi **yok eder**.

Buna bazen "black hole" denir 🕳

Ne atarsan kaybolur.

## Hepsi birleşince:

2>/dev/null

"Hata mesajlarını çöpe at" demek.

```
bandit6@bandit:~$ ls
bandit6@bandit:~$ ls -a
.  ..  .bash_logout  .bashrc  .profile
bandit6@bandit:~$ find / -type f -user bandit7 -group bandit6 -size 33c 2>/dev/null
/var/lib/dpkg/info/bandit7.password
bandit6@bandit:~$ ^C
bandit6@bandit:~$ cat /var/lib/dpkg/info/bandit7.password
morbNTDkSW6jIlUc0ymOdMaLnOlFVAaj
bandit6@bandit:~$
```

7-

grep = metin arama aracı

grep - aranılan kelime – dosya adı

```
bandit7@bandit:~$ ls
data.txt
bandit7@bandit:~$ grep millionth data.txt
millionth      dfwvzFQi4mU0wfNbFOe9RoWskMLg7eEc
```

8-

| Komut   | Görev                           |
|---------|---------------------------------|
| sort    | sıralar                         |
| uniq    | tekrarları temizler             |
| uniq -u | sadece 1 kez geçenleri gösterir |
| uniq -c | kaç kez geçtiğini sayar         |

```
bandit8@bandit:~$ ls -a
.  ..  .bash_logout  .bashrc  data.txt  .profile
bandit8@bandit:~$ sort data.txt | uniq -u
4CKMh1JI91bUIZZPXDqGanal4xvAg0JM
```

9-

## strings

Binary dosya içindeki insan okunabilir karakterleri çıkarır.

grep =

= içeren satırları gösterir.

```
bandit9@bandit:~$ ls -a
.  ..  .bash_logout  .bashrc  data.txt  .profile
bandit9@bandit:~$ strings data.txt | grep "=="
===== = the
===== = password
f\Z'===== = is
===== = FGUW5illLVJrxX9kMYMmlN4MgbpfMiqey
```

10 -

```
bandit10@bandit:~$ ls -a
.  ..  .bash_logout  .bashrc  data.txt  .profile
bandit10@bandit:~$ cat data.txt | base64 -d
The password is dtR173fZKb0RRsDFSGsg2RWnpNVj3qRr
bandit10@bandit:~$
```

Base64 = veri gizleme deęil, sadece farklı formatta gösterme.

| Soldaki komutun çıktısını saędaki komuta gönder.

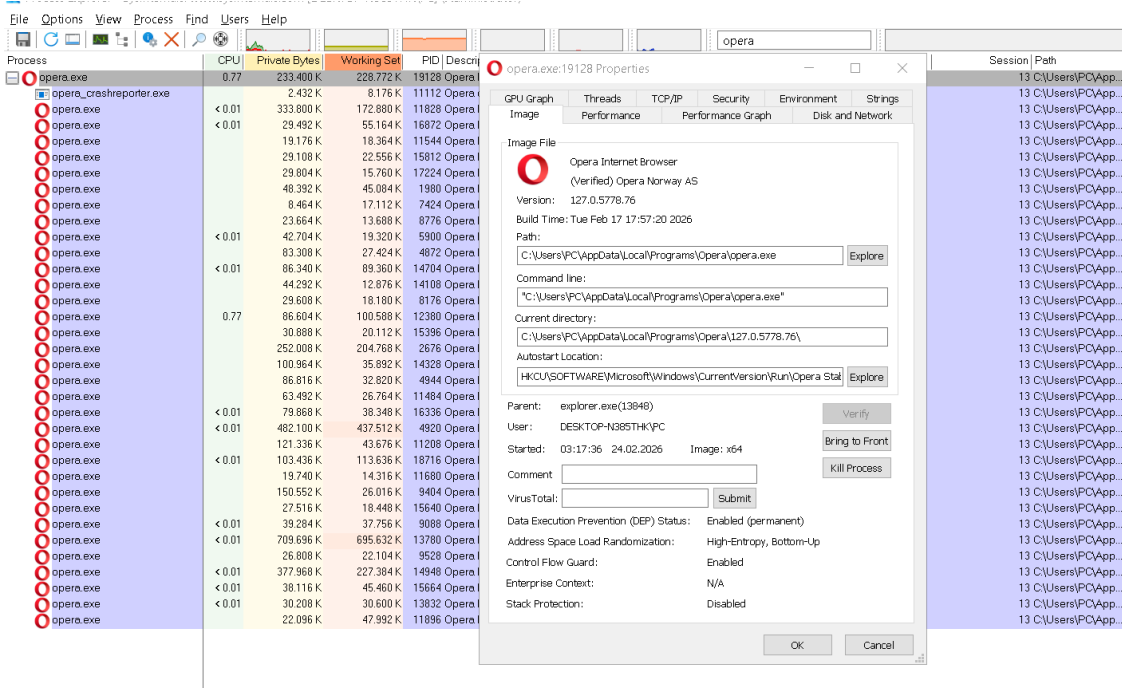
base64 normalde encode eder.

-d = decode

Base64 formatındaki veriyi gerçek haline çevir.

## Cephe 2: Sysinternals Analizi (Windows)

1-



Bir programı **çift tıklayarak** açtığında onu başlatan process genelde:

👉 **explorer.exe**

Çünkü:

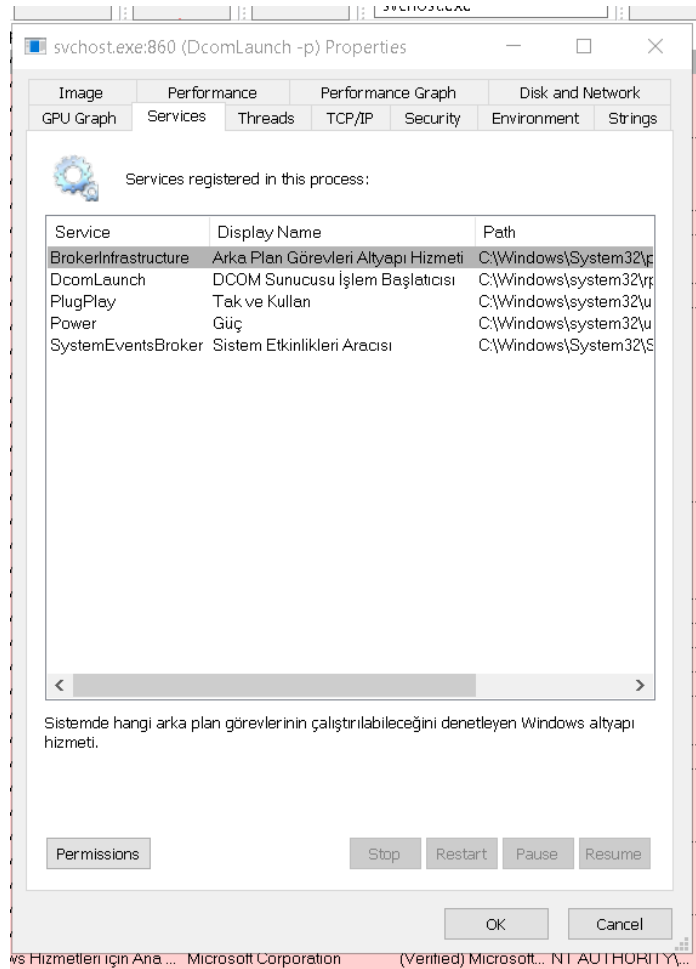
- Windows masaüstü

- Görev çubuğu
- Başlat menüsü
- Dosya yöneticisi

hepsi **explorer.exe** tarafından yönetilir.

- 1 explorer.exe senin tıklamanı algılar
- 2 explorer.exe opera.exe'yi başlatır
- 3 Bu yüzden Opera'nın **Parent process'i explorer.exe** olur

2-



3- Verify Image Signatures özelliği, imzasız veya sahte imzalı süreçleri hızlıca tespit etmeyi sağladığı için bir Malware Analisti için hayati öneme sahiptir

| Company Name ^ | Verified Signer       |
|----------------|-----------------------|
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |
| Opera Software | (Verified) Opera N... |

## 🔄 BÖLÜM D: Mühendislik Vizyonu (Reflection)

### 1. SUID + vim = Root

SUID biti şunu demek: "Bu programı kim çalıştırırsa çalıştırsın, dosyanın sahibinin (root) yetkileriyle çalıştır."

vim normalde sadece dosya açar, tamam. Ama vim içinde shell komutu çalıştırabilirsin:

vim'i aç → `#!/bin/bash` → Enter

Bu bash artık vim'in yetkileriyle açılıyor, yani **root shell**. Oradan `/etc/shadow`'u okursun (hashlenmiş parolalar), `/etc/sudoers`'a istediğini yazarsın, işin biter. "Metin editörü" lafına aldanma — eğer program sistem çağrısı yapabiliyorsa ve SUID varsa, o program bir silah.

Özet mantık: *SUID* → *program root olarak çalışır* → *program shell spawn edebilir* → *sen root olursun*.

## 2. Process Injection: Neden svchost?

İki sebep var:

**Gizlilik:** Görev yöneticisini açan herhangi biri svchost.exe'nin orada olmasını *bekler*. Zaten 10-15 tane çalışıyor olur. oyun.exe veya helper32.exe gibi bir şey görünce soru işareti oluşur, svchost görününce gözler kayar geçer.

**Yetki:** svchost.exe çoğunlukla SYSTEM hesabıyla çalışır — bu Windows'ta root'un üstü sayılır, Administrator'dan bile yetkili. Kodunu oraya enjekte ettiğinde onun token'ını miras alırsın. Kendi başına User yetkisiyle başlayıp SYSTEM'e atlamış olursun, ekstra bir PrivEsc adımına gerek kalmaz.

## Shell Spawn Etmek

"Shell" = komut satırı. Bash, sh, cmd gibi şeyler.

"Spawn etmek" = yeni bir tane açmak/doğurmak.

Yani **shell spawn etmek** = "bir program içinden komut satırı açmak" demek.

## vim'deki Exact Komut

vim açıkken şunu yazarsın:

```
:/bin/bash
```

### Ne anlama geliyor:

- : → vim'e "komut gir" moduna geç der
- ! → "bunu vim içinde değil, sistemde çalıştır" der
- /bin/bash → bash programının tam adresi (bash = komut satırı)

Yani vim'e diyorsun ki: "*Bir bash aç.*"

Vim SUID'li olduğu için bu bash **root yetkileriyle** açılıyor. Artık önünde normal bir terminal var ama içinde root'sun. Oradan:

```
cat /etc/shadow          # tüm kullanıcıların hashli şifrelerini gör
echo "saldingan ALL=(ALL) NOPASSWD:ALL" >> /etc/sudoers
# kendine tam yetki ver
gibi komutları serbestçe çalıştırırsın
```

